

CSE 508
NETWORK SECURITY — PRACTICE MIDTERM 2 (EASY)

SPRING 2026 — OPEN BOOK

100 Points

Student Name: _____

Student ID: _____

- This is an **open-book, open-notes** practice exam.
- **Please answer concisely.** Some questions have more than one correct answer.
- Answer *conceptually* — you do **not** need to write any commands, rules, or code.
- State any assumptions you make.
- If a section requires you to answer N of M questions and you answer more than N , only the first N will be graded.
- This exam has three sections:
 1. Section 1 has **2 mandatory** questions each worth **16** points.
 2. Section 2 has 5 questions out of which you have to answer **3**. Each question is worth **16** points.
 3. Section 3 has 8 questions out of which you have to answer **5**. Each question is worth **4** points.

1 Mandatory Questions (16*2=32 Points)

Answer **both** mandatory questions. Each question is worth **16 points**.

1.1 Prefix Hijacking and a Simple Defense (16 points)

Question Context: Acme Corp. is a small Internet content provider. It runs Autonomous System (AS) number 64600 and owns the public IP block 198.51.100.0/24. The block is announced to the Internet only by AS 64600. A different network, AS 64500, is operated by an attacker. AS 64500 has a Border Gateway Protocol (BGP) session with a large transit provider (AS 64700) that in turn peers with much of the Internet. None of the routers on the path perform cryptographic origin validation.

Question: Answer the following three parts.

- (a) Describe, *in words*, what the attacker AS 64500 announces to AS 64700 in order to attract traffic that was supposed to go to Acme's prefix. You do not need to write any BGP message bytes — explain what prefix it claims to originate and what its AS path looks like. **(5 points)**
- (b) Explain why other routers on the Internet may end up preferring the attacker's route over the legitimate route from AS 64600. Name at least one BGP route-selection property that makes this possible. **(5 points)**
- (c) Name *one* defense that Acme (or its upstream) could deploy to reduce the chance of this hijack propagating, and explain in one or two sentences how it helps. **(6 points)**

1.2 Why a Server Certificate Prevents Impersonation (16 points)

Question Context: Alice's browser connects to `https://bank.example` for the first time. A network attacker, Mallory, sits on the path between Alice and the bank and wants to impersonate the bank so she can read and tamper with Alice's traffic. The bank uses the standard Web public-key infrastructure (PKI): it has a certificate signed by a Certificate Authority (CA) whose root is preinstalled in Alice's browser.

Question: Answer the following three parts. You do not need to draw the TLS handshake message-by-message; give the concepts.

- (a) Explain *why* the CA-signed certificate prevents Mallory from successfully impersonating `bank.example`, even though Mallory is on the network path and can see every packet. **(6 points)**
- (b) Suppose Alice's browser ignores the certificate and accepts whatever public key the other side presents. Describe a concrete way in which Mallory can now read Alice's banking traffic. **(5 points)**
- (c) Name one thing that can still go wrong *even when Alice's browser correctly validates the certificate* — that is, a failure mode of the Web PKI itself. A one-sentence example is enough. **(5 points)**

2 Long Questions (16*3=48 Points)

Answer **3** of the 5 long questions. Each question is worth **16 points**.

2.1 Outbound SSH Defeats a Web Filter (16 points)

Question Context: Bob is a student on a university network. The university's perimeter firewall blocks outbound HTTP/HTTPS to a news site that the university considers a distraction. However, the firewall does allow outbound SSH (TCP port 22) to arbitrary hosts on the Internet, because many CS students need it for class work. Bob has shell access to a personal virtual machine, `home.example`, which sits on the open Internet and has no such filtering.

Question: Answer the following three parts.

- (a) Conceptually describe how Bob can use an SSH tunnel from his laptop to `home.example` so that his browser can reach the blocked news site. You do not need to write any commands — a short description of what is tunneled through what is enough. **(6 points)**
- (b) From the *firewall's point of view*, what does Bob's traffic look like while the bypass is in use? Why does the firewall, which only inspects packet headers, not see the blocked site's hostname? **(5 points)**
- (c) Suggest one change the university could make to its network policy to close this bypass, and briefly state the main downside of that change. **(5 points)**

2.2 Route Origin Authorization and Route Origin Validation (16 points)

Question Context: A regional Internet registry has started publishing Route Origin Authorizations (ROAs) as part of the Resource Public Key Infrastructure (RPKI). ROAs are signed records that say, in effect, “prefix P is authorized to be originated by AS X .”

Question: Answer the following three parts.

- (a) In one or two sentences each, explain (i) what a ROA binds together and (ii) what a router does when it performs Route Origin Validation (ROV) on an incoming BGP announcement. **(6 points)**
- (b) Suppose every router on the Internet performed ROV. Describe one kind of BGP hijack that ROV would clearly stop, and explain why. **(5 points)**
- (c) Name one limitation of ROA/ROV — that is, something about BGP announcements that ROA+ROV *cannot* validate on its own. One sentence is enough. **(5 points)**

2.3 ACME HTTP-01 and Multi-Perspective Validation (16 points)

Question Context: Charlie runs a small website at `blog.example`. He uses an ACME client to automatically request a TLS certificate from Let's Encrypt. The ACME server chooses the HTTP-01 challenge: it gives Charlie's client a random token, Charlie's client computes a specific response string, places it at `http://blog.example/.well-known/acme-challenge/<token>` and tells the ACME server it is ready. The server fetches that URL; if it sees the expected response, the domain is validated and a certificate is issued.

Question: Answer the following three parts.

- (a) Why does successfully serving the right content at that well-known URL count as “proof that you control the domain `blog.example`”? (6 points)
- (b) Imagine an attacker who can perform a BGP prefix hijack of `blog.example`'s IP prefix for a short time. Explain how this could, in principle, let the attacker obtain a fraudulent certificate for `blog.example`. (5 points)
- (c) Let's Encrypt performs “multi-perspective validation” (it fetches the challenge URL from multiple geographically diverse vantage points). In one or two sentences, explain how this raises the cost of the attack from part (b). (5 points)

2.4 DNS Cache Poisoning — The Attack at a High Level (16 points)

Question Context: A local DNS resolver receives a query from a client for `www.example.com`. Because it has no cached answer, the resolver sends a DNS query out to an authoritative server and then waits for the response. DNS traditionally runs over UDP and has no built-in cryptographic authentication of responses; a response is matched to its query using a 16-bit transaction ID (TXID) and the UDP source/destination ports. An attacker Eve, *off-path* (she cannot see the real query), wants the resolver to cache a wrong answer that maps `www.example.com` to an IP address Eve controls.

Question: Answer the following three parts.

- (a) At a high level, describe how Eve tries to make the resolver accept her forged response instead of the real one. Mention the fields she has to guess/forged. **(6 points)**
- (b) One classical defense is *source port randomization*. Explain in one or two sentences why it makes Eve's attack harder. **(5 points)**
- (c) Another defense is *0x20 randomization* (randomly capitalizing letters in the queried name, since DNS names are case-insensitive for matching but most resolvers copy the case back). In one or two sentences, explain the idea and *one* reason it does not always help. **(5 points)**

2.5 Perimeter Firewall vs. Zero Trust (16 points)

Question Context: “Big Widgets Inc.” has a classical network design: a corporate firewall separates the internal LAN from the Internet. Anyone who is on the internal LAN — either physically in the office or connected via the corporate VPN — is implicitly trusted and can reach any internal service. A “Zero Trust” architecture takes the opposite stance: no user or device is trusted just because of where it sits on the network; every access request to an internal resource is authenticated and authorized on its own.

Question: Answer the following three parts.

- (a) Describe one concrete attack scenario where the perimeter model lets an attacker reach internal services after only a *single* credential or device compromise. **(6 points)**
- (b) In one or two sentences, explain the main idea of Zero Trust in your own words: what does it treat as trusted, and what does it not? **(5 points)**
- (c) Name one practical downside or cost of adopting Zero Trust compared with the simple perimeter-firewall model. **(5 points)**

3 Short Questions (8 of which 5 = 20 Points)

Answer **5** of the 8 short questions. Each question is worth **4 points**.

3.1 Stateless vs. Stateful Packet Filter (4 points)

A stateless packet-filter firewall inspects each packet independently. A stateful firewall keeps a per-connection table. Give *one* concrete policy that is easy to write on a stateful firewall but very hard (or impossible) to write correctly on a purely stateless one. One or two sentences.

3.2 “NAT is Not a Firewall” (4 points)

A classmate claims “my home router has NAT, so I don’t need a firewall.” Briefly explain why NAT is *not* a security mechanism in the strict sense, even though it does happen to block many unsolicited inbound connections by default.

3.3 Why the iBGP Split-Horizon Rule Exists (4 points)

In iBGP (BGP sessions *within* a single Autonomous System), a route learned from one iBGP peer must not be re-advertised to another iBGP peer. In one or two sentences, explain the reason for this rule. (Hint: think about how BGP normally detects loops.)

3.4 MD5 Authentication on BGP Sessions (4 points)

BGP runs over TCP (port 179). As an optional defense, two BGP neighbors can pre-share a secret password out of band; each TCP segment of the BGP session then carries a keyed MD5 digest (in TCP option 19) computed over the segment plus the shared secret. The receiver recomputes the digest with its copy of the secret and silently drops any segment whose digest does not match. In one or two sentences, explain what this mechanism protects against and one important thing it does *not* protect against.

3.5 Symmetric vs. Asymmetric Keys: the Distribution Problem (4 points)

Two parties who have never communicated before want to exchange confidential messages. Briefly explain the problem you run into if you try to use symmetric-key cryptography only, and how public-key cryptography conceptually addresses it.

3.6 What Does a Valid SCT on a Certificate Mean? (4 points)

When a browser sees that a TLS certificate carries a valid Signed Certificate Timestamp (SCT) from a Certificate Transparency (CT) log, what *exactly* has been established? Equally important: what has *not* been established? One or two sentences total.

3.7 SYN Flooding and SYN Cookies (4 points)

A SYN flood attack sends many TCP SYN packets (often with spoofed source IPs) to a server and never completes the handshake. Briefly explain (i) what server resource this exhausts and (ii) the core idea of SYN cookies as a defense.

3.8 UPnP on Home Routers (4 points)

Most home routers ship with Universal Plug and Play (UPnP IGD) enabled on the LAN side so that devices can ask the router to open inbound ports for them. Give one reason why this is a security concern, framed as “what can a malicious LAN-side program now do that it otherwise could not?”